

RAPPORT D'INGÉNIERIE TECHNIQUE

Mission SENTINEL-X

Nœud IoT ESP8266, stack Docker sécurisée, IA prédictive et vision embarquée

Cadre	EPSI — Workshop Bac+4 (M1), octobre 2026
Option technique	Option B — topologie « Edge-to-Server » : le PC d'un apprenant joue le rôle de serveur local
Groupe	M1-G__
Version du document	5 octobre 2026 — dépôt prévu jeudi 8 octobre 2026
Fichier	Workshop2026-M1-G__-Dossier.pdf

ÉQUIPE (CONSORTIUM)

Membre	Filière (DEV / IA / INFRA / CYBER)	Rôle principal
Nathanaël Lejuste	DEV	API
Rémy Eroes	DEV	Dashboard & système embarqué
Amaury Malisova	DEV	IA
Guillaume Breon	DEV	Dashboard & système embarqué

00 Sommaire et synthèse

01	Architecture et schéma réseau	3
02	Schéma de câblage électronique ESP8266	5
03	Matrice de sécurité — TLS, hardening, preuves	6
04	Documentation de l'IA — maintenance prédictive et vision	8
A3	Annexe — poster A3 paysage	11

Synthèse

SENTINEL-X est un module de surveillance de table pour les centrales AetherCorp. Un nœud ESP8266 mesure la température, l'humidité, le gaz/fumée et la présence, affiche son état sur un écran OLED et pilote un buzzer et deux LED. Il publie ses mesures en MQTT chiffré (MQTTS) vers une stack Docker hébergée sur le PC portable d'un membre de l'équipe (Option B). Cette stack stocke les données dans PostgreSQL, les expose sur un tableau de bord HTTPS temps réel, et alimente un service d'IA qui détecte les dérives anormales des capteurs sans seuil statique. Une webcam USB reliée au PC alimente un service de vision YOLOv8n qui détecte les personnes et déclenche l'alarme intrusion lorsqu'elle est armée.

Conteneurs Docker	MQTT broker	Inférence YOLO / trame	Rappel spray butane	Faux incidents (holdout)
5	TLS 1.3	≈ 49 ms	20/20	0

Brique	Technologie	Emplacement
Nœud capteurs	ESP8266 NodeMCU v3, Arduino C++, PubSubClient + BearSSL	firmware/sentinel_node/
Broker	Eclipse Mosquitto 2.0.20, listener unique 8883 (TLS, ACL, anonyme refusé)	infra/mosquitto/
API + dashboard	FastAPI, WebSocket /ws, session opérateur, Bearer pour les clients machine	backend/
Base de données	PostgreSQL 16 (volume nommé, aucun port publié)	infra/docker-compose.yml
IA prédictive	Isolation Forest (scikit-learn), 8 features cinétiques	ml/
Vision	Ultralytics YOLOv8n sur CPU, flux MJPEG, service systemd utilisateur	vision/
Reverse proxy	Caddy 2.8, HTTPS 443, en-têtes de sécurité (HSTS, CSP, X-Frame-Options)	infra/caddy/Caddyfile

Toutes les valeurs chiffrées de ce rapport proviennent du dépôt (README, `ml/evaluation.md`, fichiers d'infrastructure, commentaires du firmware) ou de mesures relevées sur la machine le 5 octobre 2026.

01 Architecture et schéma réseau

Option B : le PC apprenant (Ubuntu, interface Wi-Fi `wlp0s20f3`) héberge toute la stack. Le boîtier ne contient que l'ESP8266 et ses capteurs. La webcam est branchée en USB sur le PC.

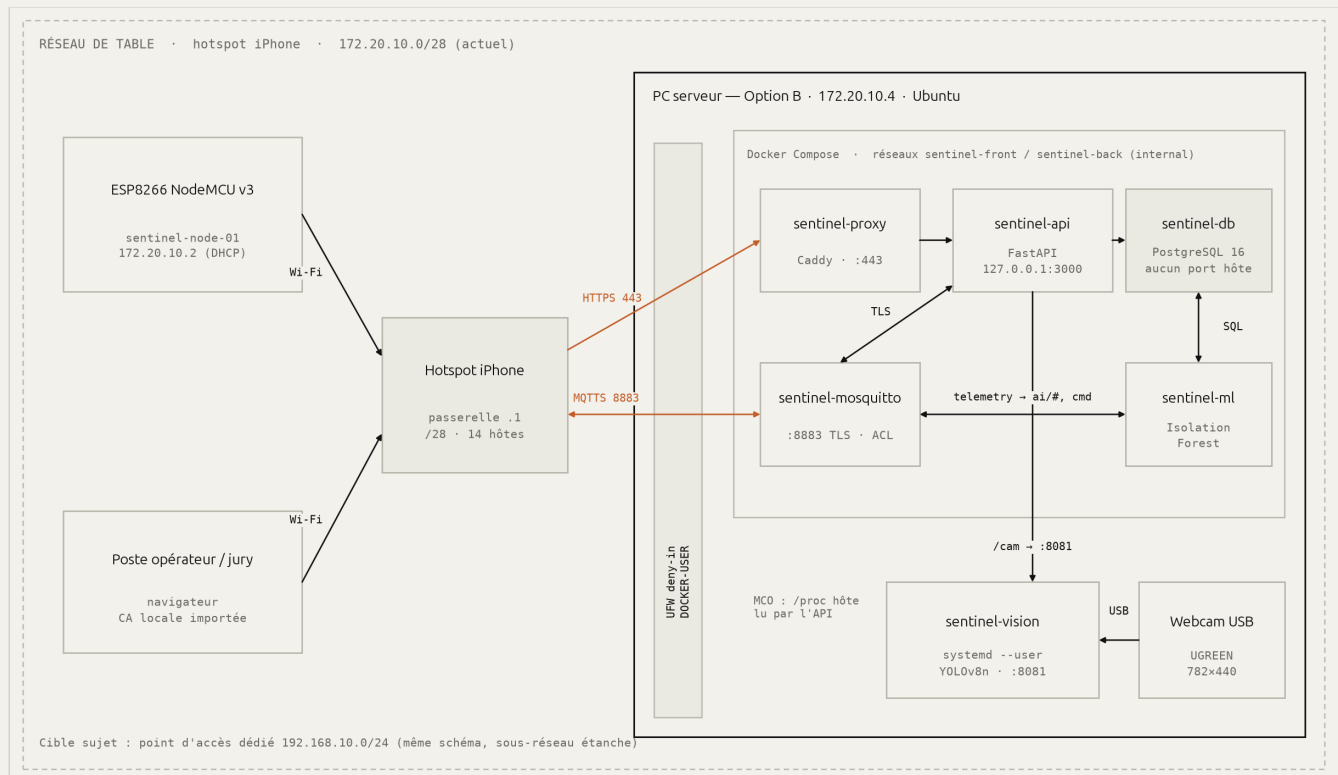


Fig. 1 – Topologie de table et flux. Accent : flux chiffrés entrants autorisés par le pare-feu.

Plan d'adressage

Élément	Actuel (hotspot iPhone)	Cible sujet (point d'accès dédié) — proposition
Sous-réseau	172.20.10.0/28 (14 hôtes utiles)	192.168.10.0/24
Passerelle / AP	172.20.10.1 (iPhone)	192.168.10.1 (AP de table)
PC serveur	172.20.10.4 (DHCP)	adresse fixe ou réservation DHCP
ESP8266 sentinel-node-01	172.20.10.2 (observé dans les journaux Mosquitto)	réservation DHCP
Règle MQTTS	8883 autorisé depuis 172.20.10.0/28 uniquement	même règle, source 192.168.10.0/24

Le /28 du hotspot limite naturellement la table à 14 hôtes et isole l'équipe des réseaux des autres groupes. Le passage sur le point d'accès dédié demandé par le sujet ne modifie que la variable `HOTSPOT_SUBNET` de `infra/harden-ning/harden.sh` et l'hôte MQTT du firmware.

Matrice des flux

Source → destination	Port / protocole	Exposition	Protection
ESP8266 → sentinel-mosquitto	8883 MQTTS	LAN, sous-réseau de table	TLS, pin SHA1 du certificat serveur, utilisateur dédié + ACL
Navigateur → sentinel-proxy	443 HTTPS	LAN	TLS (CA locale), session HttpOnly/Secure/SameSite=Strict

sentinel-proxy → sentinel-api	3000 HTTP	réseau Docker	publié seulement sur 127.0.0.1, UFW deny 3000
sentinel-api → sentinel- vision	8081 HTTP	hôte (host.docker.internal)	UFW : autorisé depuis 172.16.0.0/12, refusé ailleurs ; accès client via /cam authentifié
api / ml → sentinel-db	5432	réseau sentinel-back (internal)	aucun port hôte
api / ml → sentinel- mosquitto	8883 MQTTS	réseau Docker	TLS + comptes séparés (sentinel-ml écrit sentinel/ai/# et sentinel/+ /cmd)

Topics MQTT

Topic	Sens	Contenu
sentinel/{device_id}/telemetry	ESP → broker	JSON capteurs (température, humidité, gaz, présence, actionneurs, RSSI)
sentinel/{device_id}/alerts	ESP → broker	événements présence / actionneurs
sentinel/{device_id}/status	ESP → broker (retained)	online / offline
sentinel/{device_id}/cmd	API, ML → ESP	buzzer (songs gaz, intrus ...), LED, mode auto
sentinel/ai/<device>/risk · ai/alerts · ai/status	ML → broker	risque 0-100, incidents IA, LWT du service

Services Docker

Conteneur	Image	Ports hôte	Réseaux	Limites
sentinel-mosquitto	eclipse-mosquitto:2.0.20	8883	front, back	128 Mo · 0,5 CPU · 100 PID
sentinel-db	postgres:16-alpine	aucun	back	512 Mo · 1 CPU · 200 PID
sentinel-api	build backend/	127.0.0.1:3000	front, back	512 Mo · 1 CPU · 200 PID
sentinel-ml	build ml/	aucun	front, back	768 Mo · 1 CPU · 200 PID
sentinel-proxy	caddy:2.8-alpine	443	front	128 Mo · 0,5 CPU · 100 PID

Journaux Docker en rotation (json-file, 10 Mo × 3 fichiers par conteneur) pour éviter la saturation du disque sous l'afflux de messages MQTT. Le bloc MCO du dashboard (/api/v1/system) suit CPU, RAM et disque de l'hôte, le débit MQTT et l'état des sondes mosquitto / db / ml / nœud.

02 Schéma de câblage électronique ESP8266

Carte NodeMCU v3 alimentée en USB. Affectation des broches relevée dans `firmware/sentinel_node/sentinel_node.ino` : « DHT22 D5 | PIR D6 | MQ-2 A0 | OLED SDA D2 / SCL D1 | Buzzer D7 | LED rouge D0 | LED verte D8 ».

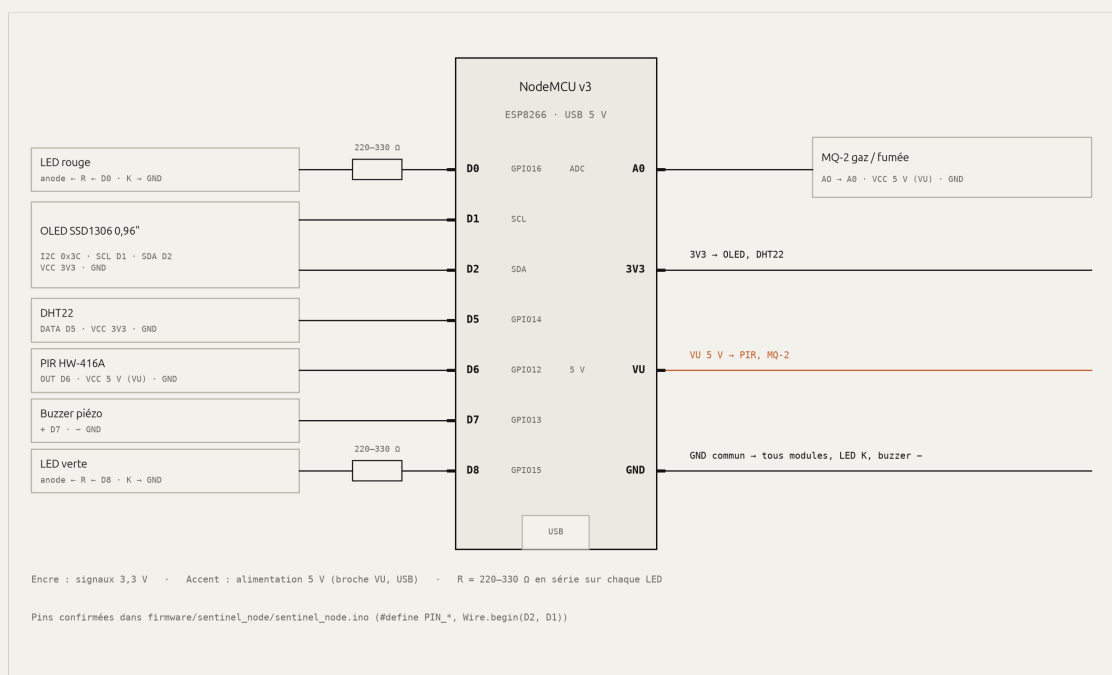


Fig. 2 – Câblage du nœud sentinel-node-01.

Composant	Broche ESP	Alimentation	Remarque
DHT22 (température / humidité)	D5 (GPIO14)	3V3 · GND	lecture toutes les 2 s (limite du capteur)
OLED SSD1306 0,96" I2C	D1 SCL · D2 SDA	3V3 · GND	adresse 0x3C, Wire.begin(D2, D1) ; affiche IP, état MQTTs, alertes
PIR HW-416A	D6 (GPIO12)	5 V (VU) · GND	sortie logique 3,3 V ; anti-rebond logiciel
MQ-2 gaz / fumée	A0 (sortie A0)	5 V (VU) · GND	chauffe nécessaire après mise sous tension
Buzzer piézo	D7 (GPIO13)	– · GND	sirènes gaz et intrus (alarms.h)
LED rouge	D0 (GPIO16)	via R 220-330 Ω → GND	présence, alarme ; clignote si déconnecté
LED verte	D8 (GPIO15)	via R 220-330 Ω → GND	connecté, RAS

Points d'attention

- **D8 / GPIO15** doit être au niveau bas au démarrage : la LED et sa résistance vers GND jouent le rôle de pull-down, ne pas y brancher de pull-up.
- **A0** : l'entrée analogique de la NodeMCU accepte 0-3,3 V grâce à son pont diviseur. Le MQ-2 étant alimenté en 5 V, vérifier que la tension AO reste dans cette plage (un pont diviseur externe sinon).
- **Masse commune** à tous les modules ; le 5 V est pris sur VU (USB). **Cadence** : le firmware actuel publie la télémétrie toutes les 0,5 s (TELEMETRY_MS), le DHT22 n'est relu que toutes les 2 s ; le modèle IA raisonne sur une période nominale de 2 s.
- **PIR** : jugé instable sur table, il reste publié dans la télémétrie mais l'alarme intrusion s'appuie sur la vision YOLO.

03 Matrice de sécurité

Source : docs/matrice-securite.md, preuves issues de infra/hardening/verify.sh (docs/preuves-securite.txt, exécution du 5 octobre 2026, 14:07) et contrôles complémentaires du 5 octobre 2026 vers 15:00.

Menace	Vecteur (jury / pentest)	Impact	Mitigation implémentée	Risque résiduel
MitM / sniffing MQTT	Wireshark sur le hotspot	Lecture télémetrie, injection de commandes	MQTTS (port 8883, TLS 1.2 minimum, négocié en TLS 1.3), certificat avec SAN, authentification + ACL ; ESP : pin SHA1 du certificat (MQTT_CERT_FINGERPRINT)	CA auto-signée à importer dans les navigateurs
Injection de payload MQTT	Client rogue / Metasploit	Commandes ESP, fausses alertes	allow_anonymous false, ACL par rôle, mots de passe forts générés	Compromission d'un secret MQTT
DoS broker	Flood connexions / messages	Perte de la supervision	max_connections 50, max_inflight_messages 20, max_queued_messages 100, max_packet_size 8192, rotation des logs, limites CPU/RAM	DoS L2/L3 (Wi-Fi) hors MQTT
Brute force API	POST login / commandes	Prise de contrôle du dashboard	Session HttpOnly + Secure + SameSite=Strict, rate-limit login (8/min/IP) et commandes (30/min/IP), Bearer API_TOKEN pour les clients machine	Mot de passe opérateur faible s'il n'est pas changé
Exposition de services	Nmap	Surface d'attaque	UFW (deny par défaut) + chaîne DOCKER-USER ; 1883, 3000 et 8081 non exposés au LAN ; HTTPS seul pour l'interface	Retour d'un bind 0.0.0.0
Accès physique ESP	Vol, dump flash	Secrets Wi-Fi / MQTT	secrets.h hors git, utilisateur MQTT dédié restreint par ACL	Flash lisible avec accès physique
Évasion de conteneur	CVE / mauvaise config Docker	Accès hôte	non-root, read_only, cap_drop ALL, no-new-privileges, limites de ressources	Docker rootful
Client MQTT illégitime	Connexion avec un mauvais compte	Lecture / écriture hors périmètre	ACL stricte par utilisateur	Fuite du fichier .env
Accès caméra	URL directe du flux	Fuite d'images	Flux servi par l'API sur /cam/* derrière authentification ; port 8081 filtré	—

État du durcissement

Mesure	État	Preuve / commentaire
MQTTS 8883, port 1883 fermé	● FAIT	openssl s_client : TLSv1.3, TLS_AES_256_GCM_SHA384 ; MQTT anonyme refusé ; 1883 non joignable ; seul listener 8883 dans mosquitto.conf
ESP en MQTTS avec pin du certificat	● FAIT	setFingerprint(MQTT_CERT_FINGERPRINT) , buffers TLS 2048/512 ; connexions sentinel-node-01 depuis 172.20.10.2 visibles côté broker. Choix du pin SHA1 : fonctionne hors ligne sans NTP.
HTTPS 443 (Caddy)	● FAIT	TLSv1.3 ; HSTS, CSP, X-Frame-Options DENY, nosniff, Referrer-Policy, en-tête Server retiré
Authentification dashboard / API	● FAIT	compte operateur (mot de passe hors git), cookie de session, WebSocket refusé sans session (code 4401)
Caméra derrière authentification	● FAIT	GET https://127.0.0.1/cam/health sans session → 401 (contrôle du 5 octobre 2026)

UFW	● ACTIF	deny incoming par défaut ; allow 443, 80 (Apache hôte) ; 8883 depuis 172.20.10.0/28 ; deny 3000 ; 8081 depuis 172.16.0.0/12 puis deny
DOCKER-USER	● FAIT	bloc SENTINEL-X dans /etc/ufw/after.rules + règle iptables immédiate : 8883 abandonné hors sous-réseau de table
Conteneurs durcis	● PARTIEL	api, ml, proxy : read-only, cap_drop ALL (proxy : NET_BIND_SERVICE seul), api/ml non-root. mosquito et db : no-new-privileges + limites, mais ni read-only ni cap_drop (entrypoints officiels)
SSH par clé uniquement	● PRÉPARÉ	openssh-server non installé : aucun port 22 exposé. harden.sh applique la configuration clé ed25519 seule (99-sentinel.conf) si le service est installé.
sysctl réseau	● FAIT	/etc/sysctl.d/99-sentinel.conf appliqué
Docker rootless / userns-remap	● NON FAIT	recommandation, nécessite de reconfigurer dockerd hors démo
fail2ban, nmap de contrôle	● NON FAIT	non installés ; nmap à prévoir pour la vérification avant pentest

À traiter avant jeudi. Docker publie des ports en contournant UFW. Sur l'hôte, d'autres conteneurs hors projet publient 3002, 3100 et 9090 sur 0.0.0.0, et la chaîne DOCKER-USER actuelle les laisse passer. Un Nmap adverse les verra. Il faut les filtrer dans DOCKER-USER ou arrêter ces services pendant le pentest. Les ports 139/445 (Samba hôte) sont bloqués par la politique UFW par défaut.

Extraits de preuves

```
### openssl s_client MQTTS :8883
subject=C = FR, O = SENTINEL-X, OU = EPSI-M1, CN = sentinel.local
issuer=C = FR, O = SENTINEL-X, OU = EPSI-M1, CN = SENTINEL-X Local CA
New, TLSv1.3, Cipher is TLS_AES_256_GCM_SHA384

### MQTT anonyme refusé (8883)      OK: anonyme refusé (ou TLS requis)
### Port 1883 fermé sur l'hôte      OK: 1883 fermé / non joignable

### UFW status
Default: deny (incoming), allow (outgoing), deny (routed)
443/tcp    ALLOW IN  Anywhere      # SENTINEL HTTPS
3000/tcp   DENY IN   Anywhere      # SENTINEL api deny
8883/tcp   ALLOW IN  172.20.10.0/28 # SENTINEL MQTTS hotspot
8081/tcp   ALLOW IN  172.16.0.0/12  # SENTINEL vision docker
8081/tcp   DENY IN   Anywhere      # SENTINEL vision deny others
```

Preuve Wireshark à réaliser sur le hotspot pendant la démo : filtre tcp.port==8883, charge utile illisible (TLS).

04 Documentation de l'IA

4.1 Maintenance prédictive — Isolation Forest

Le service `sentinel-ml` ne contient aucune règle du type `if temp > 40`. Un modèle **Isolation Forest** (scikit-learn, 300 arbres, contamination 0,005) apprend la dynamique normale des capteurs et signale les anomalies cinétiques : dérives, montées rapides, corrélations suspectes. Les seuils de décision sont **appris** à partir des quantiles du score sur l'historique normal, et non fixés sur une valeur capteur.

FEATURES (ML/FEATURES.PY)

Feature	Fenêtre	Ce qu'elle capte
<code>gas_dev_rel</code>	ligne de base EWMA $\approx$ 5 min	écart relatif du gaz à sa ligne de base (micro-déviations, fuite)
<code>gas_slope_30s</code>	30 s	pente du gaz (spray butane : montée brutale)
<code>gas_std_30s</code>	30 s	turbulence du panache
<code>gas_slope_2m</code>	2 min	dérive lente du gaz
<code>temp_slope_2m</code>	2 min	échauffement lent ($^{\circ}\text{C}/\text{min}$)
<code>temp_dev</code>	ligne de base EWMA $\approx$ 10 min	écart de température
<code>hum_slope_2m</code>	2 min	variation d'humidité (assèchement lors d'un échauffement)
<code>gas_temp_corr</code>	2 min	corrélations gaz $\times$ température : hausse lente de T° et micro-déviations de gaz

Features directionnelles. L'Isolation Forest est symétrique par nature. Avant le modèle, `vectorize()` ne conserve que le sens du danger (hausse de gaz, échauffement, chute d'humidité, corrélation gaz-température positive) et met à zéro les baisses et les retours à la normale. Une décroissance bénigne, comme le gaz qui redescend après un essai, n'est plus prise pour une anomalie. Autres garde-fous : filtre médian sur 3 échantillons contre les glitches ADC ; ligne de base presque gelée ($\times 0,05$) pendant une anomalie pour ne pas « absorber » une fuite ; réinitialisation de l'état au redémarrage de l'ESP (chauffe du MQ-2).

DÉCISION ET ACTIONS

- Score d'anomalie = `-score_samples()` sur features standardisées.
- Risque 0-100 interpolé entre la médiane normale (0), la vigilance q98 (30), le seuil d'anomalie appris (50) et un incident extrême de référence (100).
- Type d'incident selon la contribution des features (z-scores robustes médiane/MAD) : groupe gaz $\rightarrow$ `gaz_fumee`, groupe thermique $\rightarrow$ `thermique`, sinon `anomalie`.
- Persistance : 4 fenêtres anormales consécutives ($\approx$ 8 s) pour lever l'incident, 5 normales pour le clore.
- Prédiction (pré-alerte sans son) si le risque lissé monte en zone de vigilance dans le sens d'un danger.

État	Action
<code>prediction</code>	alerte <code>ia_prediction/risque_croissant</code> sur le journal et le dashboard, sans son
<code>gaz_fumee</code>	alerte <code>ia_gaz</code> , sirène <code>gaz</code> en boucle, LED rouge fixe ; réarmement 60 s après « Couper alarme » si le gaz persiste
<code>thermique</code>	alerte <code>ia_thermique</code> , LED rouge, bandeau dashboard
<code>anomalie</code>	alerte <code>ia_anomalie/anomalie_cinetique</code> (journal et dashboard)

ÉVALUATION (ml/EVALUATION.MD , GÉNÉRÉ LE 5 OCTOBRE 2026 À 14:56, GRAINE 42)

Entraînement sur 1 004 fenêtres réelles de `sentinel-node-01` (5 octobre 2026, 11:40 → 14:14, heure de Paris) et 4 016 fenêtres augmentées (bruit MQ-2 ±10 ADC, DHT22 ±0,5 °C / ±2 %RH, scénarios « personne proche » traités comme normaux). Les essais réels (briquet, chauffage du DHT22, capteur débranché, chauffés après reboot) sont exclus via `ml/training_exclusions.json`. Split temporel 80 / 20.

Rappel spray butane (≤ 12 s) 20/20	Latence alarme 8 s médiane · max 10 s	Faux incidents (holdout) 0 192 fenêtres · 0,11 h	Glitches isolés ignorés 20/20	Dérives lentes avant règle 4/4
--	--	---	---	--

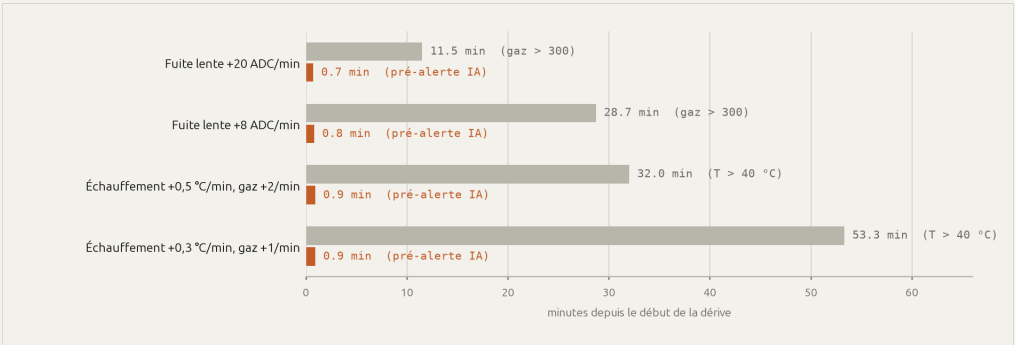


Fig. 3 – Dérives lentes simulées : première pré-alerte IA comparée au franchissement d'une règle statique (`ml/evaluation.md` §3).

Scénario	Pré-alerte IA	Incident confirmé	Règle statique	Avance IA
Fuite lente +20 ADC/min	0,7 min	0,8 min (gaz_fumee)	11,5 min (gaz > 300)	10,8 min
Fuite lente +8 ADC/min	0,8 min	non	28,7 min (gaz > 300)	27,9 min
Échauffement +0,5 °C/min, gaz +2 ADC/min	0,9 min	6,2 min (thermique)	32,0 min (T > 40 °C)	31,1 min
Échauffement +0,3 °C/min, gaz +1 ADC/min	0,9 min	6,7 min (anomalie)	53,3 min (T > 40 °C)	52,4 min

Rejeu de l'historique réel (2 865 mesures, 11:40 → 14:49, heure de Paris) : 7 incidents ou escalades, dont 6 `gaz_fumee` correspondant aux essais de gaz réalisés, et 10 épisodes de pré-alerte.

Limites. L'historique normal réel couvre quelques heures d'une seule journée et le holdout normal seulement 0,11 h : le taux de faux positifs reste à confirmer sur une durée plus longue. Les incidents `thermique` et `anomalie` du rejeu sont à traiter comme « à vérifier ». Réentraîner après plusieurs heures de fonctionnement normal en étiquetant les essais.

4.2 Vision — YOLOv8n

Le service `sentinel-vision` (systemd utilisateur, `vision/vision_service.py`) lit la webcam UGREEN par son chemin stable `/dev/v4l/by-id/...`, capture en 1280×720 MJPEG puis redimensionne en **782×440** avant l'inférence. Ce bridage en amont tient la contrainte du sujet (moins de 100 ms par trame). YOLOv8n tourne sur CPU, limité à la classe « personne » avec une confiance minimale de 0,45 ; l'inférence est cadencée à 0,12 s au plus (≈ 8 FPS).

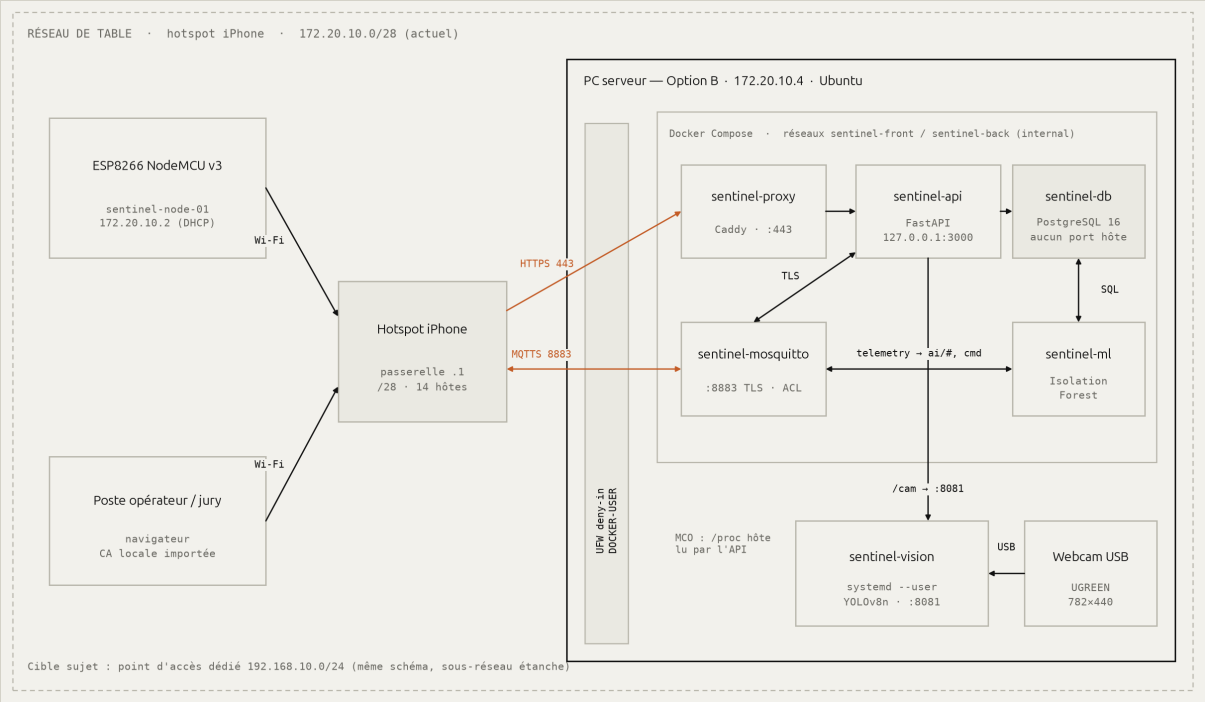
Inférence moyenne (30 trames) 49,0 ms	Dernière trame 44,8 ms	Pic ponctuel (≈ 1 h) 105 ms	Débit inférence / flux 20,4 · 9,8 inf/s · FPS	Résolution 782×440
---	----------------------------------	---------------------------------------	--	------------------------------

Relevé sur `/health` du service `vision`, 5 octobre 2026 vers 15:00.

Le temps d'inférence s'affiche en incrustation sur le flux et dans le bloc « Vision IA » du dashboard (`infer_ms`). Sur `person_detected`, le service publie une alerte (`POST /api/v1/alerts`, Bearer). Si l'alarme présence est armée, l'API déclenche la sirène `intrus` pendant 15 s. Pendant une alerte gaz, la sirène intrus est inhibée.

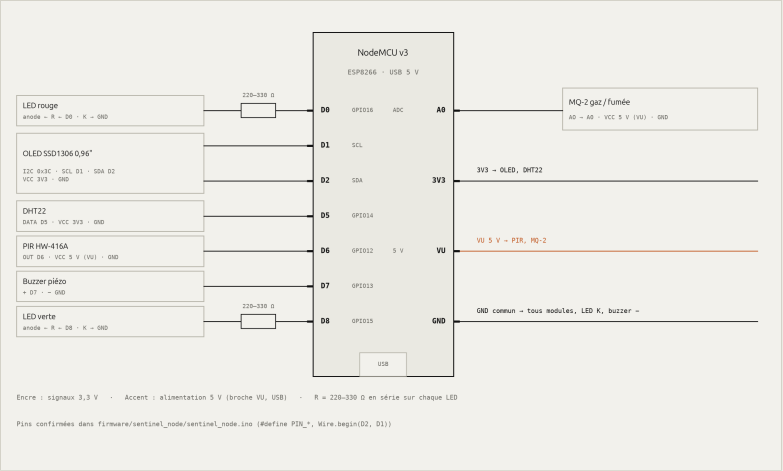
Rappel spray butane 20/20 alarme en 8 s (médiane)	Avance sur règle statique 11–52 min 4/4 dérives lentes	Faux incidents 0 holdout normal 0,11 h	Inférence YOLOv8n 49 ms CPU · 782×440 · < 100 ms	Flux chiffrés TLS 1.3 MQTTs 8883 · HTTPS 443	Ports SENTINEL exposés 2 443 · 8883 (sous-réseau de table)
--	---	---	---	---	---

ARCHITECTURE



ESP8266 → MQTTS → Mosquitto → API FastAPI → PostgreSQL / WebSocket → dashboard HTTPS. Le service IA s'abonne à la télémétrie et pilote la sirène. La vision YOLO tourne sur le PC, à côté de la webcam.

NŒUD DE TABLE



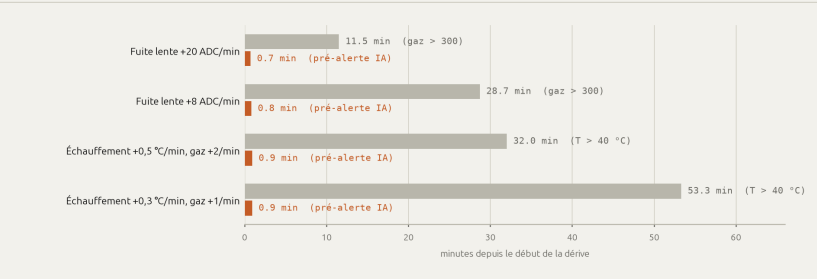
Capteur / actionneur	Broche
DHT22 · OLED I2C	D5 · D1/D2
PIR HW-416A · MQ-2	D6 · A0 (5 V)
Buzzer · LED rouge · LED verte	D7 · D0 · D8

SÉCURITÉ

- MQTTS + pin du certificat, ACL par rôle, anonyme refusé
- HTTPS Caddy, session HttpOnly, rate-limit, caméra authentifiée
- UFW deny par défaut + DOCKER-USER
- Conteneurs read-only, cap_drop ALL, limites

IA PRÉDICTIVE

Isolation Forest, 300 arbres, 8 features cinétiques directionnelles. Pas de seuil fixe : le risque 0-100 est calibré sur les quantiles appris du score.



RÉPONSE

prediction	pré-alerte silencieuse
gaz_fumee	sirène gaz + LED rouge
thermique	LED rouge + bandeau
intrusion	sirène intrus 15 s (si armée)

01 · CAPTER

DHT22, MQ-2, PIR, OLED d'état ; webcam USB sur le PC serveur

02 · TRANSPORTER

MQTTs 8883, pin du certificat, comptes et ACL par rôle

03 · ANALYSER

Isolation Forest sur 8 dynamiques capteurs ; YOLOv8n ≈ 49 ms par trame

04 · ALERTER

sirène gaz / intrus, LED, dashboard HTTPS temps réel, journal PostgreSQL